



Kanban-доска

Разработка веб-сервиса управления задачами

Отчёт по учебной / производственной практике · Кейс №3

Выполнил: ст. гр. БИВТ-24-9, Кукишев А.В.

Задача и требования

- Многопользовательский сервис Kanban-досок (аналог Trello, Kaiten)
- Доска имеет владельца и участников с разными ролями
- Колонки и карточки; перемещение drag-and-drop, порядок в колонке
- Исполнитель, срок выполнения, комментарии к карточкам
- Пароли — только в виде хэшей, доступ по токену
- Транзакции и защита от коллизий при одновременном редактировании

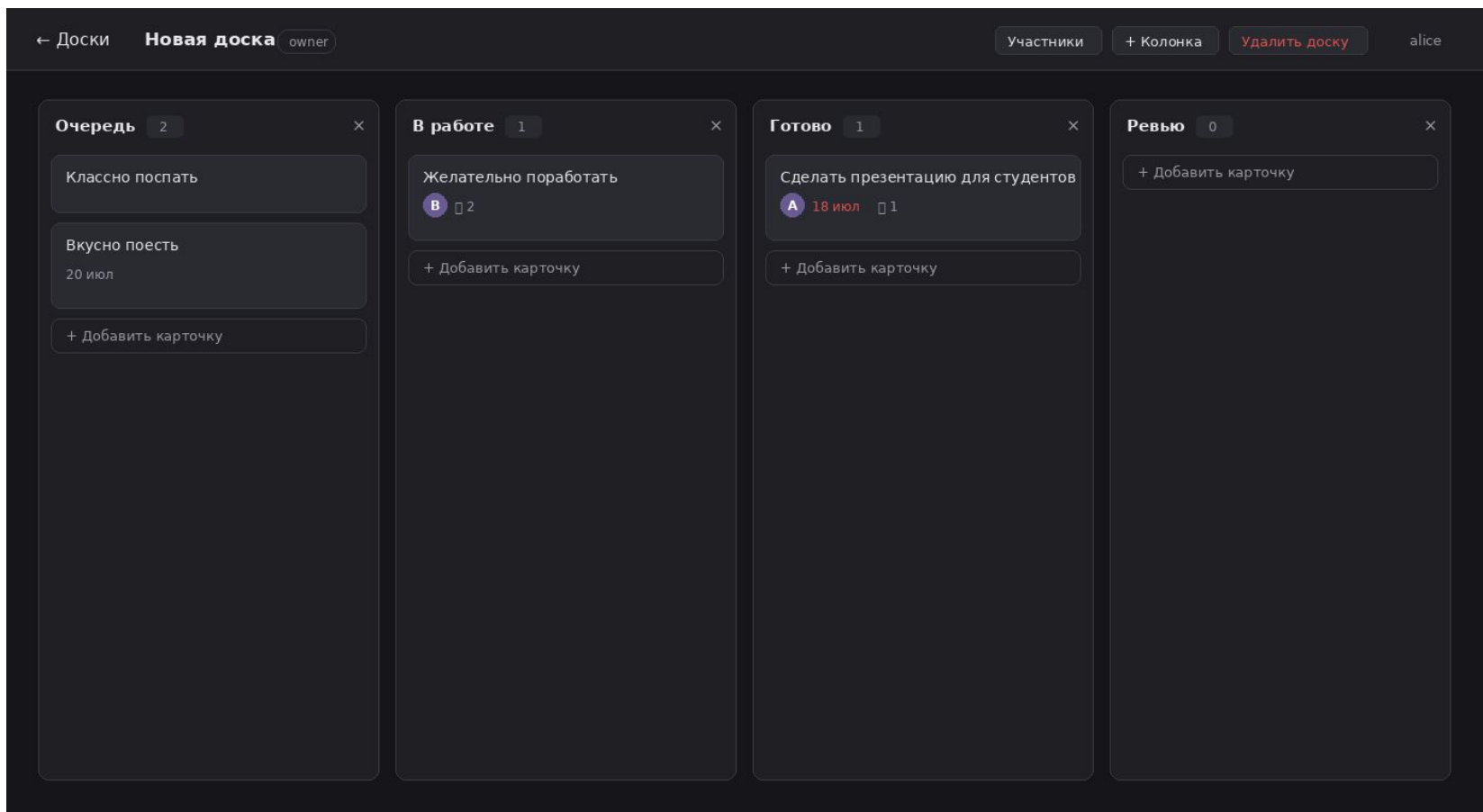
Обязательный минимум

6 групп требований
выполнены полностью

Сверх минимума

Журнал изменений (audit log)
Оптимистичная блокировка
Swagger-документация

Что получилось



Рабочая область доски

- Список досок с ролью
- Колонки со счётчиком
- Перетаскивание карточек
- Исполнитель и срок
- Просроченные — красным
- Комментарии в карточке

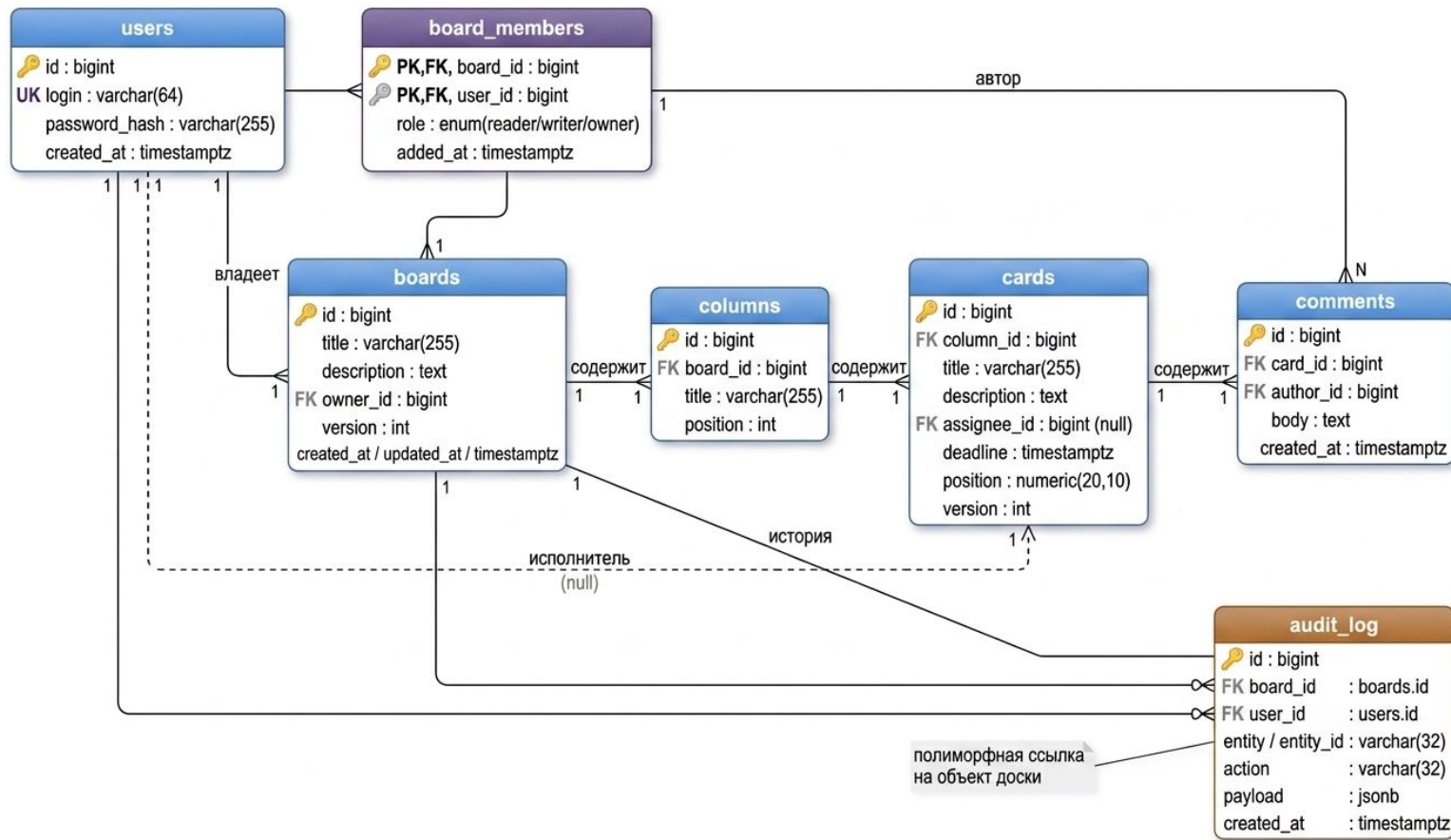
Архитектура



Клиент не обращается к базе напрямую. Все операции идут через сервер — это даёт единую точку контроля доступа, валидации данных и управления транзакциями.

Слой сервера: модели → схемы валидации → сервисы (бизнес-логика) → маршруты REST

Модель данных



- 7 таблиц
- N:N «пользователь ↔ доска» через board_members с ролью
- audit_log — история изменений
- Каскадные удаления
- 7 индексов под частые выборки
- JOIN, GROUP BY, оконные функции

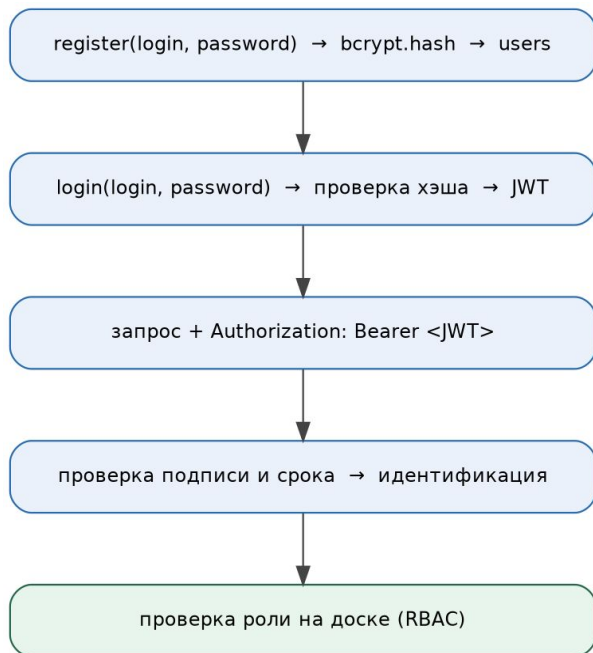


Программный интерфейс (REST)

Метод	Конечная точка	Назначение	Мин. роль
POST	/api/auth/register	Регистрация	—
POST	/api/auth/login	Вход, выдача токена	—
GET / POST	/api/boards	Список и создание досок	—
GET / PATCH / DELETE	/api/boards/{id}	Операции с доской	reader / owner
GET / POST	/api/boards/{id}/columns	Колонки	reader / writer
GET / POST	/api/boards/{id}/cards	Карточки	reader / writer
POST	/api/cards/{id}/move	Перемещение карточки	writer
GET / POST	/api/cards/{id}/comments	Комментарии	reader / writer
GET	/api/boards/{id}/audit	Журнал изменений	owner

Документация OpenAPI генерируется автоматически и доступна на /docs

Модель авторизации



- Логин и пароль → JWT (HS256, 24 часа)
- Все защищённые методы работают с токеном
- Пароли — bcrypt со встроенной солью
- Действия фиксируются в журнале

Плохо

password: my_password_123

Безопасно — реализовано

password_hash: \$2b\$12\$...

401 — нет/просрочен токен

403 — недостаточно прав

404 — нет доступа к доске

Ролевая модель: RBAC

Роль	Чтение	Редактирование	Администрирование	Управление ролями
Читатель (reader)	Да	Нет	Нет	Нет
Писатель (writer)	Да	Да	Нет	Нет
Владелец (owner)	Да	Да	Да	Да

Почему RBAC, а не ABAC

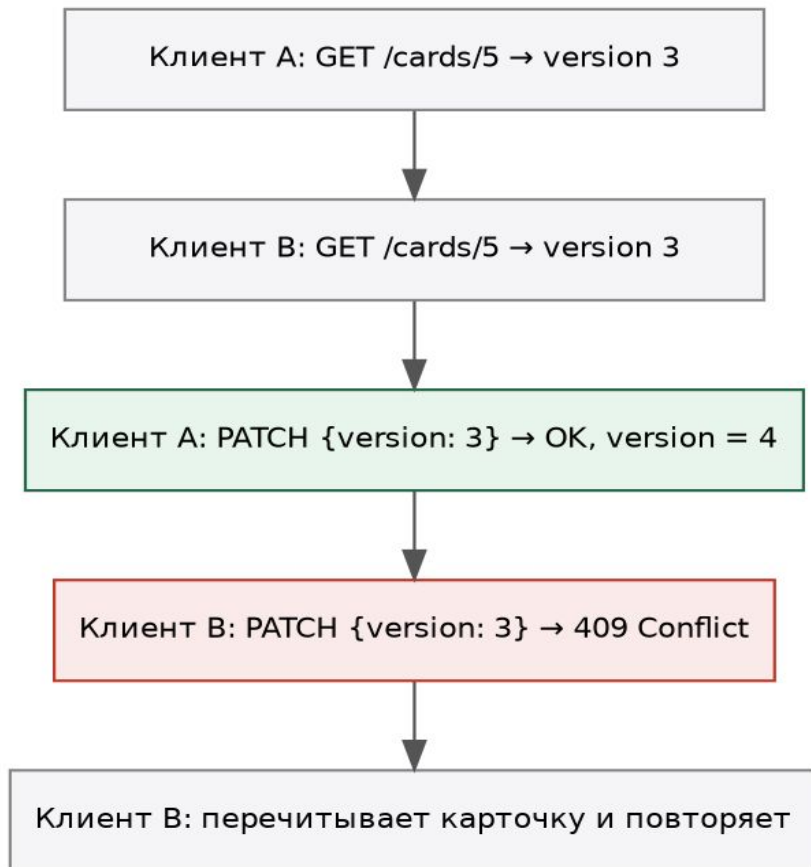
Права полностью описываются тремя ролями на доске. Динамических атрибутивных правил (время, отдел, гриф) в задаче нет — ABAC был бы избыточным усложнением.

Минимальные привилегии

Чужая доска возвращает 404, а не 403 — сам факт её существования не раскрывается. Проверка прав вынесена в единую функцию для всех маршрутов.



Транзакции и защита от коллизий



- Оптимистичная блокировка: поле version у досок и карточек
- Несовпадение версий → 409 Conflict, клиент перечитывает состояние
- Перемещение карточки — одна транзакция: колонка + позиция + версия + журнал
- Не удерживает блокировки в БД, лучше масштабируется, чем SELECT FOR UPDATE

Порядок карточек в колонке



Дробное индексирование

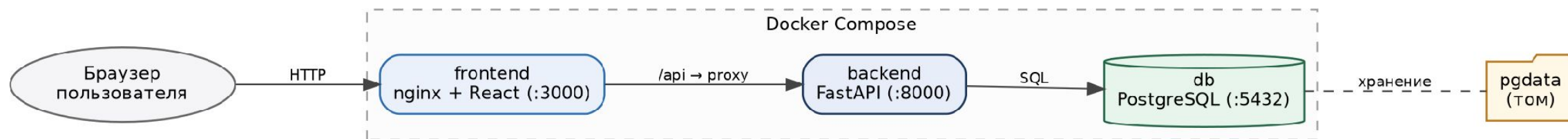
Позиция — число с плавающей точкой.

Вставка между А и В: $pos = (A + B) / 2$

Перемещение изменяет
одну запись вместо пересчёта позиций всей колонки.

Позиции карточек хранятся в поле NUMERIC(20,10)

Развёртывание



```
docker compose up --build
```

Запуск всей системы одной командой

- Три контейнера: база, сервер, клиент с nginx
- Миграции применяются автоматически при старте
- База наполняется демонстрационными данными
- Данные сохраняются в отдельном томе

Тестирование

Вход по логину и паролю	Выдан токен	✓
Создание и перемещение карточки	Смена колонки, рост версии	✓
Перемещение с устаревшей версией	409 Conflict	✓
Запись пользователем-читателем	403 Forbidden	✓
Обращение к чужой доске	404 Not Found	✓
Запрос без токена	401 Unauthorized	✓
Фиксация действий в журнале	Записи созданы	✓

11

сценариев

11

пройдено

10 / 10

артефактов

Выводы и развитие

Что сделано

- Все требования MVP выполнены
- Ролевая модель и авторизация по токену
- Транзакции и защита от коллизий
- Журнал изменений сверх минимума
- Воспроизводимое развёртывание

Направления развития

- Метки и чек-листы карточек
- Вложения к карточкам
- Полнотекстовый поиск
- Шаблоны досок
- Обновление в реальном времени (веб-сокеты)

Спасибо за внимание

Готов ответить на вопросы

